

SIMATS ENGINEERING
ASSESSMENT TOOL I – SCENARIO-BASED ASSESSMENT (HIGH)

Course Name: Ethical Hacking for Secure Networks	Code: ITA1436	CO: CO2
Duration: 90 min Date:	Total Marks:	Reg. No / Name : 19231053

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks. (BL3)
Assessment Tool Weightage: 35%

Instructions: Answer all questions. Each question carries 10 marks.

Scenario 1: A cybersecurity analyst has been assigned to conduct a security assessment for a multinational company. Before performing any active scanning, the analyst collects publicly available information about the target organization. Using tools such as WHOIS, Recon-ng, and online search engines, the analyst gathers domain registration details, IP address ranges, and contact information. The collected data will be used to identify potential attack surfaces and security weaknesses.

Questions:

1. Explain how WHOIS can be used during footprinting.
2. What information can Recon-ng gather about a target organization?
3. Why is passive information gathering preferred before active scanning?

Scenario 2: A technology startup plans to launch a new cloud-based service in a highly competitive market. To understand industry trends, a security consultant is asked to analyze competitor websites and online presence. The consultant uses tools such as BuiltWith and SimilarWeb to identify technologies, hosting platforms, and traffic patterns. The information collected will help the startup improve its security posture and business strategy.

Questions:

1. How does BuiltWith help in competitive intelligence?
2. What type of information can SimilarWeb provide?
3. How can competitive intelligence improve cybersecurity planning?

Scenario 3: A financial organization wants to evaluate the security of its public-facing infrastructure. During reconnaissance, an ethical hacker performs DNS enumeration to identify available DNS records. The investigation reveals several subdomains and mail server configurations that were not properly documented. The security team must determine whether this information could be exploited by attackers.

Questions:

1. What is DNS enumeration?
2. Which DNS records are commonly collected during reconnaissance?
3. How can exposed DNS information create security risks?

Scenario 4: An ethical hacker is conducting a reconnaissance exercise for a client organization. Using advanced search engine operators, the hacker discovers publicly accessible files containing employee directories and configuration documents. Some of these documents reveal details about internal systems. The organization wants to know how such information became publicly accessible.

Questions:

1. What is search engine footprinting?
2. How do search operators help locate sensitive information?
3. What steps should organizations take to protect confidential files?

Scenario 5: A company's DNS administrator receives reports that unauthorized users may have accessed DNS information. During an investigation, the security team discovers that the DNS server allows unrestricted zone transfers. As a result, attackers can obtain a complete list of internal and external hosts. The organization needs to secure its DNS infrastructure immediately.

Questions:

1. What is a DNS zone transfer?
2. Why is unrestricted zone transfer considered a security risk?
3. How can organizations prevent unauthorized zone transfers?

Code of Conduct:

I S Venkata Abhishek(192311053)(Name / Reg. No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:Abhishek

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Scenario	20%				
Identification of Key Issues	20%				
Application of Concepts	25%				
Decision Making	20%				
Clarity of Response	15%				

Criteria	Understanding of Scenario	Identification of Key Issues	Application of Concepts	Decision Making	Clarity of Response	Total
Q1						
Q2						
Q3						
Q4						
Q5						

Scenario 1: Footprinting and Reconnaissance

1. Explain how WHOIS can be used during footprinting.

WHOIS is a query service used to obtain registration information about Internet domains and IP address allocations. During footprinting, a security analyst can use WHOIS to collect publicly available information about a target organization.

Information obtained through WHOIS may include:

- Domain name and registrar details.
- Domain registration and expiry dates.
- Name servers associated with the domain.
- Registrant or administrative contact information, when publicly available.
- Organization or domain owner information.
- Technical contact details in some cases.
- Information about IP address ownership and allocation.

For example, an analyst investigating `example.com` may identify its registrar, name servers, registration information, and associated organization. This information can help map the organization's external infrastructure.

WHOIS is useful because it provides an initial understanding of the target's Internet presence **without directly interacting with its systems**. However, privacy-protection services may hide some registration details.

Conclusion: WHOIS is an important passive footprinting technique that helps analysts understand domain ownership, registration information, and the external infrastructure associated with an organization.

2. What information can Recon-ng gather about a target organization?

Recon-ng is a reconnaissance framework designed to automate the collection of publicly available information about a target. It uses various modules and data sources to organize reconnaissance information.

Recon-ng can help gather:

1. Domain names and subdomains.
2. IP addresses and network information.
3. DNS-related information.
4. Email addresses associated with an organization.
5. Employee or contact information when publicly available.
6. Hostnames.
7. URLs and web-related information.
8. Information from search engines and public databases.
9. Social-media or publicly available profile information, depending on available modules and APIs.
10. Information about related organizations and infrastructure.

The collected information can be stored in a structured database, making it easier for security professionals to analyze relationships between domains, hosts, people, and networks.

For example, an analyst may start with a company's primary domain and use Recon-ng to discover associated subdomains and publicly known email addresses.

Conclusion: Recon-ng helps automate and organize OSINT-based reconnaissance, allowing security teams to build a clearer picture of an organization's attack surface.

3. Why is passive information gathering preferred before active scanning?

Passive information gathering is preferred initially because it collects information **without directly interacting with the target's systems**.

Important reasons include:

1. **Low risk:** It is less likely to disrupt target systems.
2. **Reduced detection:** Passive activities generally do not generate scanning traffic against the target.
3. **Legal and ethical safety:** Publicly available information can be collected without attempting unauthorized access.
4. **Better planning:** Analysts can understand the target before conducting active tests.
5. **Reduced unnecessary scanning:** Known domains, IP ranges, and technologies can be identified first.
6. **Attack-surface mapping:** It helps identify potential systems that require further assessment.
7. **Efficient testing:** Active scanning can then be focused on relevant systems.

For example, an analyst can first use search engines, WHOIS, public DNS information, and public websites before performing port scanning.

Conclusion: Passive reconnaissance provides a safer and more efficient starting point for security assessments and helps analysts perform subsequent active testing in a controlled manner.

Scenario 2: Competitive Intelligence

1. How does BuiltWith help in competitive intelligence?

BuiltWith is a technology profiling service that can identify technologies used by websites. In competitive intelligence, it helps organizations understand the technical architecture and technology choices of competitors.

BuiltWith can identify technologies such as:

- Web servers.
- Content management systems.
- JavaScript frameworks and libraries.
- Web analytics platforms.
- Advertising and marketing technologies.
- Hosting or cloud-related technologies.
- Security technologies.
- E-commerce platforms.
- Content delivery networks and other web services.

For example, if a competitor uses a particular CMS, CDN, analytics platform, or web framework, a company can study that technology and compare it with its own infrastructure.

From a cybersecurity perspective, identifying technologies can also help security teams understand potential technology-specific risks and ensure that their own systems are properly maintained.

Conclusion: BuiltWith provides technology intelligence that helps organizations understand competitors' web technologies and make informed technical and strategic decisions.

2. What type of information can SimilarWeb provide?

SimilarWeb provides information about website traffic and online audience behavior. It can be used to understand the online performance and visibility of competitors.

Typical information includes:

- Estimated website traffic.
- Traffic sources.
- Search traffic.
- Referral traffic.
- Social traffic.
- Audience interests and demographics, where available.
- Geographic distribution of visitors.
- Popular pages or engagement-related metrics.
- Competitor and industry comparisons.
- Search keywords and online marketing information, depending on the available service level.

For example, a company can use SimilarWeb to determine whether a competitor receives significant traffic from search engines, social media, referrals, or direct visits.

This information can help organizations understand competitors' online strategies and identify areas where they may need to improve their own presence.

Conclusion: SimilarWeb provides web-traffic and audience intelligence that can support both business analysis and security planning.

3. How can competitive intelligence improve cybersecurity planning?

Competitive intelligence can improve cybersecurity planning by helping organizations understand the technologies, infrastructure, and online exposure of competitors and the wider industry.

It can help organizations:

- Identify commonly used technologies and security controls.
- Understand industry attack surfaces.
- Identify technologies that may require additional security controls.
- Compare their security posture with industry practices.
- Identify exposed services or technologies that should be minimized.
- Improve risk assessment and threat modeling.
- Prioritize security investments.
- Understand how competitors manage their public-facing infrastructure.

For example, if intelligence shows that organizations in the same industry commonly expose certain web technologies, a security team can specifically assess those technologies for vulnerabilities and configuration weaknesses.

Conclusion: Competitive intelligence gives cybersecurity teams additional context for risk assessment, technology selection, attack-surface management, and security strategy.

Scenario 3: DNS Enumeration

1. What is DNS enumeration?

DNS enumeration is the process of identifying and collecting DNS-related information about a target domain or organization.

The Domain Name System (DNS) converts domain names into information such as IP addresses and identifies services such as mail servers.

During DNS enumeration, a security professional may identify:

- Domain names.
- Subdomains.
- IP addresses.
- Name servers.
- Mail servers.
- DNS configuration information.
- Other publicly available DNS records.

For example, an organization may have:

example.com
mail.example.com
vpn.example.com
portal.example.com

Identifying these subdomains helps security professionals understand the organization's externally visible infrastructure.

DNS enumeration is useful during authorized security assessments because it helps identify systems that should be included in the security assessment.

Conclusion: DNS enumeration is an important reconnaissance technique for mapping an organization's domain and externally visible network infrastructure.

2. Which DNS records are commonly collected during reconnaissance?

Several DNS record types are useful during reconnaissance:

DNS Record	Purpose
A	Maps a domain/hostname to an IPv4 address
AAAA	Maps a domain/hostname to an IPv6 address
MX	Identifies mail servers
NS	Identifies authoritative name servers
CNAME	Creates an alias from one domain name to another
TXT	Stores text information, often including security-related records
SOA	Provides administrative information about a DNS zone
PTR	Performs reverse DNS mapping from IP address to hostname

For example, an **MX record** can reveal the mail infrastructure of an organization, while **NS records** identify the authoritative DNS servers.

Conclusion: Collecting DNS records helps security professionals build a map of the organization's publicly visible infrastructure.

3. How can exposed DNS information create security risks?

Exposed DNS information is not automatically a vulnerability because DNS is designed to provide publicly accessible information. However, excessive or poorly managed information can help attackers understand an organization's infrastructure.

Potential risks include:

- Discovery of forgotten or vulnerable subdomains.
- Identification of administrative portals.
- Identification of development or testing systems.
- Discovery of mail infrastructure.
- Identification of third-party services.
- Better understanding of the organization's network structure.
- Easier targeting of outdated or misconfigured systems.
- Assistance in social engineering and phishing attacks.

For example, a forgotten subdomain pointing to an old server could provide attackers with an additional target.

Organizations should therefore review DNS records regularly, remove obsolete records, avoid unnecessary information exposure, and ensure that discovered systems are properly secured.

Conclusion: DNS information can assist attackers in reconnaissance, so organizations should maintain accurate DNS records and minimize unnecessary exposure.

Scenario 4: Search Engine Footprinting

1. What is search engine footprinting?

Search engine footprinting is the process of using search engines to gather publicly available information about an organization, its employees, websites, systems, and online resources.

Search engines index large amounts of publicly accessible content. Security professionals can use this information during reconnaissance to understand an organization's digital footprint.

Information may include:

- Websites and subdomains.
- Public documents.
- Employee information.
- Job postings.
- Technical documentation.
- Publicly indexed files.
- Information about technologies used by an organization.
- Publicly accessible configuration or documentation files.

Search engine footprinting is generally a passive reconnaissance technique because the analyst obtains information that has already been made publicly accessible.

Conclusion: Search engine footprinting helps security professionals identify what information about an organization is already exposed on the Internet.

2. How do search operators help locate sensitive information?

Search operators allow users to make searches more specific. During an authorized security assessment, they can help identify publicly indexed files and information that should not be exposed.

Examples include:

- `site:` — restricts results to a particular website or domain.
- `filetype:` — searches for particular file types such as PDF or DOCX.
- `intitle:` — searches for specific words in page titles.
- `"exact phrase"` — searches for an exact phrase.

For example, a security team auditing its own domain could use:

`site:example.com filetype:pdf`

to identify publicly indexed PDF documents.

Similarly, searching for specific terms can reveal whether internal documentation or other sensitive information has accidentally become publicly accessible.

These operators do not bypass access controls; they help locate information that search engines have already indexed.

Conclusion: Search operators make search-engine footprinting more precise and help organizations discover accidentally exposed information.

3. What steps should organizations take to protect confidential files?

Organizations should take the following measures:

8. **Apply proper access controls** to confidential documents.
9. **Remove sensitive files from public web servers** when they are not required.
10. **Configure web servers correctly** to prevent unintended directory listing.
11. **Use authentication and authorization** for internal documents.
12. **Avoid storing passwords, API keys, or confidential configuration information in public files.**
13. **Review search-engine indexing regularly.**
14. **Request removal of sensitive cached/indexed content when necessary.**
15. **Use encryption** for sensitive information.
16. **Classify documents according to sensitivity.**
17. **Conduct regular security audits and vulnerability assessments.**
18. **Train employees** about secure document handling.
19. **Monitor public-facing systems** for accidental information disclosure.

Conclusion: Confidential information should never rely on obscurity. Proper access control, secure configuration, monitoring, and regular audits are essential to prevent accidental exposure.

Scenario 5: DNS Zone Transfers

1. What is a DNS zone transfer?

A DNS zone transfer is a mechanism used to copy DNS zone information from one DNS server to another.

It is commonly used to synchronize DNS information between:

Primary DNS servers.

Secondary DNS servers.

Common types include:

AXFR: Full zone transfer.

IXFR: Incremental zone transfer, which transfers only changes to the zone.

A legitimate zone transfer allows secondary DNS servers to maintain an up-to-date copy of the DNS zone.

For example, when an organization has a primary DNS server and several secondary DNS servers, zone transfers ensure that all authorized servers have consistent DNS information.

Conclusion: DNS zone transfers are legitimate administrative mechanisms, but they must be restricted to authorized DNS servers.

2. Why is unrestricted zone transfer considered a security risk?

An unrestricted zone transfer can allow an unauthorized person to retrieve a large amount of DNS information from a DNS server.

A successful unauthorized transfer may reveal:

- Hostnames.
- Subdomains.
- IP addresses.
- Mail servers.
- Internal or external infrastructure details.
- Development and testing systems.
- Network naming conventions.

This provides attackers with a detailed map of the organization's infrastructure and can make reconnaissance easier.

For example, instead of discovering individual subdomains one by one, an attacker might obtain a large list of hosts through an improperly configured zone transfer.

The information itself may not directly provide unauthorized access, but it can significantly reduce the attacker's reconnaissance effort and help identify high-value targets.

Conclusion: Unrestricted zone transfers violate the principle of least privilege and expose unnecessary infrastructure information to unauthorized users.

3. How can organizations prevent unauthorized zone transfers?

Organizations can prevent unauthorized DNS zone transfers by implementing the following controls:

- **Allow zone transfers only to authorized secondary DNS servers.**
- **Use IP-based access control lists (ACLs)** to restrict transfer requests.
- **Disable zone transfers** where they are not required.
- **Use TSIG (Transaction Signature) authentication** to authenticate DNS zone-transfer requests.
- **Separate internal and external DNS infrastructure** where appropriate.
- **Regularly review DNS server configurations.**
- **Monitor DNS logs** for unauthorized transfer attempts.
- **Keep DNS server software updated and securely configured.**
- **Follow the principle of least privilege.**
- **Conduct periodic security assessments** to verify that unauthorized transfers are not possible.

Conclusion: DNS zone transfers should be permitted only between trusted DNS servers. Proper ACLs, authentication, segmentation, monitoring, and secure configuration can prevent unauthorized access to zone information.